

Security & Compliance Mapping

How the prototype's design aligns with the CMS requirements in the SOO. This is a prototype; items marked *(design)* show the intended production control that the architecture supports but that is not fully implemented in the demo.

Data protection (PII/PHI)

Requirement	Implementation
Encrypt sensitive data at rest	Consumer PII is field-level encrypted with a KMS CMK (backend/src/lib/crypto.ts) before persistence; DynamoDB tables also use KMS SSE
PII visible only to the accepting agent	Plaintext PII is returned only in the agentAccept response after a successful accept; it is never sent over WebSocket or to non-accepting agents
Encrypt in transit	TLS at API Gateway/CloudFront (<i>design</i> ; <i>local dev uses http</i>)
Least-privilege access	Scoped IAM policy per Lambda role (infra/terraform/iam.tf) restricting DynamoDB/KMS/SNS/SES/States actions
Key rotation	KMS key rotation enabled (infra/terraform/kms.tf)

Identity & access (NEE / RBAC)

Requirement	Implementation
Agent/broker accounts after required training	Cognito user pool; account provisioning gated externally (<i>design</i>)
Unique profile keyed to NPN + email	npn is the primary key in ran-agents ; email is unique per Cognito user
Multi-state coverage from CMS license validation	licensedStates is treated as CMS-provided; agents may deselect but never add states (agentProfileUpdate enforces subset)
Proficient languages from MLMS	Languages are CMS-provided (MLMS profile); not editable in-app — agentProfileUpdate rejects language changes with a pointer to portal.cms.gov
Role separation (agent vs admin)	Cognito groups agents / admins ; API authorizer + getIdentity role checks
Biometric mobile acceptance	Cognito + device biometrics (<i>design</i> ; <i>mobile-responsive UI is PWA-ready</i>)

Consumer-facing requirements

Requirement	Implementation
Section 508 / WCAG 2.1 AA	Semantic HTML, labeled inputs, <code>aria-live</code> status, visible focus, skip link, keyboard operable (<code>frontend/src/pages/Consumer.tsx</code> , <code>styles.css</code>)
Third-party redirect disclaimer	Shown before submission on the consumer form
Limited-use-of-information notice	Included in the consumer disclaimer block
Non-endorsement notice	Consumer form states referrals do not constitute an endorsement by CMS, HHS, or the U.S. Government of any individual agent or broker
TCPA consent	Required checkbox; server rejects submissions without consent
Consumer intake fidelity	Form collects ZIP + city/state, preferred contact method (Phone/Email), phone type (Mobile/Home/Work); email required only when Email is the preferred method
Co-branding to HealthCare.gov style	Palette/typography modeled on the HealthCare.gov style in <code>styles.css</code>
Stay active on HealthCare.gov	Consumer flow is embeddable; status updates push without navigation

Operations & oversight

Requirement	Implementation
Real-time admin dashboard	Live metrics (response time, acceptance rate, reroutes, safety-net count, concurrency) via polling + WebSocket refresh
Configurable business rules	Admin can edit referral timeout, safety-net timeout, max attempts, proximity weight, missed-referral deactivation threshold, password rotation days (<code>ran-config</code>)
Timer-based auto-reassignment	Step Functions <code>waitForTaskToken</code> + <code>TimeoutSeconds</code> reroutes unaccepted referrals
After-hours Consumer Safety Net	When no agent is available, emails all licensed agents in the state; first-come-first-serve atomic claim; email-only; no penalty (<code>sfnSafetyNet</code>)
Configurable availability	Per-agent standard weekly hours, "Today's Availability" temporary override with a stop timestamp, and "Out of Office" extended absence
Status lifecycle for reporting	accept / reject / in progress / completed / not a good referral captured per request

Requirement	Implementation
Missed-referral tracking	Timed-out referrals increment a per-agent counter; agents see a missed-referral notice on login; consistent misses flag deactivation risk
24-hour accepted-referral reminder	Agent UI flags referrals still in Accepted status after 24 hours
Account deactivation rules	Admin compliance panel flags agents over the missed-referral threshold, with passwords older than 180 days, or lapsed annual training
Annual training contingency	<code>trainingCurrent</code> flag gates matching eligibility; lapsed training surfaces in compliance flags
Concurrency targets (25k consumers / 2.5k agents / 5 admins)	Serverless, horizontally scaling primitives; targets surfaced in the admin capacity panel

Hosting

- Target: **AWS GovCloud** only. Terraform is region-parameterized (`-var region=us-gov-west-1`) and free of non-GovCloud assumptions.

Audit & logging (*design*)

- All Lambdas emit CloudWatch logs; production would add structured audit events for PII access (who accepted which referral and when) and CloudTrail on KMS decrypt operations, satisfying CMS ARS audit controls.